

ACME Global Security Standard v3.0

Confidential - Internal Use Only

Generated by Gemini Reasoning Engine

1.0 Identity & Access Management (IAM)

Document ID: POL-SEC-IAM-001

Version: 1.4

Last Reviewed: October 15, 2023

Approval Authority: Chief Information Security Officer (CISO)

1.0 Identity & Access Management (IAM)

1.1 Purpose

This policy establishes the mandatory framework for managing digital identities and controlling logical access to all information systems, applications, and data assets owned or managed by the organization. The primary objective is to ensure that access to sensitive information and critical systems is restricted to authorized individuals and processes, thereby protecting the confidentiality, integrity, and availability of company resources. This policy is designed to enforce the principle of least privilege and to provide a clear audit trail for all access-related activities, in accordance with regulatory requirements and industry best practices. Adherence to this policy is essential for maintaining our security posture and compliance with standards such as ISO 27001 and SOC 2.

1.2 Scope

This policy is applicable to all employees, contractors, temporary staff, third-party vendors, and any other individuals or automated systems (collectively known as "users") that require access to the organization's corporate network, cloud environments, software applications, databases, and infrastructure. This policy governs the entire lifecycle of an identity, from creation and provisioning to modification and de-provisioning, across all technology platforms, including but not limited to on-premises servers, cloud service provider environments (e.g., AWS, Azure, GCP), and Software-as-a-Service (SaaS) applications.

1.3 Policy Statements

1.3.1 User Authentication Controls

Authentication is the process of verifying a user's identity. All authentication mechanisms must adhere to the following controls:

Multi-Factor Authentication (MFA): The use of Multi-Factor Authentication is mandatory for all human users for interactive login to any system that supports it. This control must be enforced without exception for access to critical infrastructure, administrative consoles, and systems containing sensitive data. Approved MFA factors include FIDO2-compliant hardware security keys and time-based one-time password (TOTP) applications. The use of SMS-based MFA is deprecated and strictly prohibited for new integrations.

Password Complexity: Where passwords are used as an authentication factor, they must meet a minimum complexity requirement of 14 characters, including at least one uppercase letter, one lowercase letter, one number, and one special character.

1.3.2 Authorization and Principle of Least Privilege

Access to information resources must be granted based on the principle of least privilege. Users shall only be granted the minimum level of permissions necessary to perform their explicitly defined job responsibilities. Role-Based Access Control (RBAC) must be implemented wherever technically feasible. All access requests must be formally documented and approved by the relevant data owner or department manager.

1.3.3 Privileged Access Management

Root Account Usage: The use of the root account or equivalent superuser accounts (e.g., AWS root user, Global Administrator) for any operational, administrative, or daily task is strictly prohibited. Access to these accounts must be secured within a digital vault, require multi-person approval for checkout, and its usage must trigger a high-priority, real-time alert to the Security Operations Center (SOC). The only permissible use of a root account is for initial account setup or in a documented break-glass emergency recovery scenario, as authorized by the CISO.

1.3.4 Access Key and Credential Management

All programmatic credentials, including API keys, service account keys, and other secrets used for system-to-system communication, are subject to stringent management controls.

Mandatory Key Rotation: All programmatic access keys and secrets must be programmatically rotated at a maximum interval of ninety (90) calendar days. Any key that has exceeded this lifetime must be automatically disabled. Any key suspected of compromise must be immediately revoked and rotated, and the incident must be reported to the security team.

Secure Storage: Credentials must never be hardcoded in source code, configuration files, or scripts. All secrets must be stored and retrieved using the company-approved secrets management solution.

1.3.5 Access Reviews and Auditing

All user access permissions must be reviewed on a quarterly basis by the user's manager or the designated system owner to ensure continued business need. All authentication and authorization events, including successful and failed attempts, must be logged and forwarded to the central Security Information and Event Management (SIEM) system in accordance with the Log Management Policy (DOC-SEC-004). These audit logs shall be retained for a minimum of 365 days. Any deviation from this policy must be formally documented in an exception request form and approved by the Designated Compliance Officer.

2.0 Object Storage (S3)

2.0 Object Storage (S3)

2.1 Purpose

This policy chapter establishes the mandatory security controls, configurations, and operational procedures for the use of Amazon Web Services (AWS) Simple Storage Service (S3). The primary objective of this policy is to protect the confidentiality, integrity, and availability of all organizational data stored within S3 buckets. Adherence to these standards is critical for mitigating risks associated with data exposure, unauthorized access, data loss, and regulatory non-compliance. This policy, version 2.4, supersedes all previous versions and is effective immediately upon publication. All personnel are required to acknowledge their understanding and commitment to these regulations.

2.2 Scope

This policy applies to all AWS accounts owned or managed by the organization, including all Production, Staging, Development, and Sandbox environments. It is binding for all full-time employees, part-time employees, contractors, consultants, and third-party vendors who are granted access to, or are responsible for creating or managing, S3 resources. This policy governs the entire lifecycle of S3 objects, from creation and storage to access, transfer, and eventual deletion. Any S3 bucket, regardless of its intended use or the data it contains, falls under the jurisdiction of this policy. Exemptions to any clause herein must be formally requested through the Security Governance Risk and Compliance (GRC) portal and receive explicit written approval from the Chief Information Security Officer (CISO).

2.3 Technical Controls

The following technical controls are mandatory and represent the minimum acceptable security baseline for all S3 resources. Automated compliance checks will continuously monitor for adherence to these standards.

2.3.1 Access Control and Public Exposure

Public access to S3 buckets is strictly prohibited. All four "Block Public Access" settings (Block public access to buckets and objects granted through new access control lists, Block public access to buckets and objects granted through any access control lists, Block public access to buckets and objects granted through new public bucket or access point policies, and Block public and cross-account access to buckets and objects through any public bucket or access point policies) must be set to 'True' at both the AWS account level and for each individual S3 bucket. It is forbidden to create or modify bucket policies or Access Control Lists (ACLs) that grant anonymous or public read/write access. Any configuration identified as public will be flagged as a critical vulnerability and subject to immediate automated remediation.

2.3.2 Data Encryption at Rest

All data stored within S3 buckets must be encrypted at rest. The mandatory minimum level of encryption is Server-Side Encryption with Amazon S3-Managed Keys (SSE-S3), which utilizes the AES-256 block cipher. While SSE-S3 is the minimum requirement, the use of Server-Side Encryption with AWS Key Management Service (SSE-KMS) is the strongly preferred standard for buckets containing sensitive, proprietary, or regulated data. Buckets found without default encryption enabled will be considered a direct policy violation. The Compliance Officer will review

all encryption configurations during scheduled quarterly audits as documented in the official Audit Log (Ref: AL-S3-Q3-2024).

2.3.3 Data Integrity and Versioning

To protect against accidental data deletion, corruption, or malicious modification, S3 Versioning must be enabled on all buckets designated as part of a Production environment. This control is mandatory and non-negotiable for Production data. Enabling versioning provides a mechanism to preserve, retrieve, and restore every version of every object stored in a bucket, forming a critical component of our disaster recovery and business continuity strategy. For Development and Staging buckets, enabling versioning is highly recommended.

2.3.4 Logging and Monitoring

To ensure complete visibility and audibility of data access patterns, AWS CloudTrail data events for S3 and S3 server access logging must be enabled for all buckets containing sensitive or Production-level data. Logs must be configured to be delivered to a separate, dedicated, and highly restricted S3 logging bucket. This logging bucket must itself comply with all policies outlined in this chapter, including encryption and the blocking of public access. All generated logs must be retained for a minimum of 365 days and forwarded to the organization's centralized Security Information and Event Management (SIEM) solution for real-time analysis and alerting.

3.0 Compute Security (EC2)

3.0 Compute Security (EC2)

3.1 Purpose

The purpose of this policy is to establish the mandatory security requirements for the configuration, deployment, and management of all Amazon Elastic Compute Cloud (EC2) instances and related resources within the organization's AWS environment. Adherence to this policy is essential to protect company data, maintain system integrity, and ensure the availability of critical services. This policy aims to mitigate risks associated with unauthorized access, data breaches, and system misconfigurations by enforcing a defense-in-depth security posture for all virtual server workloads.

3.2 Scope

This policy applies to all EC2 instances, Amazon Machine Images (AMIs), Elastic Block Store (EBS) volumes, Security Groups, and Elastic Load Balancers within all company-managed AWS accounts. This policy is binding for all full-time employees, part-time employees, contractors, and third-party vendors who are involved in the provisioning, administration, or maintenance of AWS EC2 resources. This policy supersedes any previous informal guidelines or practices concerning EC2 security.

3.3 Technical Controls and Implementation

3.3.1 Network Access and Firewall Configuration

The principle of least privilege must be strictly applied to all network access controls.

It is mandatory that all Security Groups are configured with a default-deny posture for all inbound traffic. Rules allowing traffic must be explicit, justified, and limited to the narrowest possible source IP range and specific required ports.

Administrative access ports, specifically TCP port 22 (SSH) and TCP port 3389 (RDP), are strictly prohibited from being exposed to the public internet (0.0.0.0/0 or ::/0). Any Security Group rule found in violation of this control will be subject to immediate automated remediation and will trigger a high-priority security alert.

All administrative access to EC2 instances located in private subnets must be facilitated through a dedicated, hardened bastion host (also known as a jump box) located in a separate, secured subnet. The bastion host's Security Group must only permit SSH access from organizationally-controlled IP address ranges. The target EC2 instances must, in turn, have Security Group rules that only permit SSH access from the private IP address or Security Group ID of the designated bastion host.

3.3.2 Instance Hardening and Configuration

All EC2 instances must be launched from a company-approved, hardened Amazon Machine Image (AMI). The approved AMIs are maintained by the Cloud Operations team and are based on the latest Center for Internet Security (CIS) Benchmarks, Level 1. The current mandatory AMI series is 'Corp-Secure-AMI-v5.2.3' or newer. The use of public or unvetted AMIs is strictly prohibited without a formal security exception.

All instances must be configured with the unified CloudWatch agent to forward security, system, and application logs to the centralized logging account. These logs, as detailed in the organizational Logging and Monitoring Policy (Doc Ref: 4.5), must be retained for a minimum of 365 days. Audit logs pertaining to privileged access must be archived for a period no less than seven (7) years, as per regulatory compliance requirements overseen by the appointed Compliance Officer, Johnathan Miller.

3.3.3 Identity and Access Management (IAM)

EC2 instances must not contain static, long-lived IAM user credentials (Access Key ID and Secret Access Key). It is mandatory for all instances to be assigned an IAM Role at launch. The permissions attached to this IAM Role must adhere to the principle of least privilege, granting only the specific permissions necessary for the application's function.

3.3.4 Data Encryption

All data at rest on Elastic Block Store (EBS) volumes must be encrypted. It is mandatory to enable the "Encrypt this EBS volume" setting for all new volumes using the designated AWS Key Management Service (KMS) Customer Master Key (CMK), identified by the alias `alias/corp-standard-ebs-key`. The account-level "EBS encryption by default" setting must be enabled in all regions.

3.4 Policy Enforcement and Compliance

Compliance with this policy will be continuously monitored through automated tools, including AWS Config and AWS Security Hub. Any deviation from this policy will be flagged as a non-compliant finding and will generate an alert for the Information Security team.

Failure to comply with the mandatory controls outlined in this chapter may result in the immediate termination of the non-compliant resource, revocation of AWS access privileges, and may lead to disciplinary action, up to and including termination of employment or contract.

This policy chapter will be reviewed and updated on an annual basis, or more frequently if significant changes occur in the threat landscape or AWS service offerings. All proposed changes must be reviewed and approved by the Chief Information Security Officer (CISO).

4.0 Database Security (RDS)

4.0 Database Security (RDS)

4.1 Purpose

This policy chapter establishes the mandatory security requirements for the provisioning, configuration, and management of all Amazon Relational Database Service (RDS) instances and clusters within the organization's cloud environment. The primary objective is to protect the confidentiality, integrity, and availability of company and customer data stored within these databases. Adherence to this policy is critical for maintaining our security posture, meeting contractual obligations, and demonstrating compliance with regulatory frameworks such as SOC 2 Type II and ISO/IEC 27001. This document provides the baseline security controls that all personnel must implement to mitigate risks associated with data exposure, unauthorized access, and data loss.

4.2 Scope

This policy applies to all Amazon RDS instances, including but not limited to PostgreSQL, MySQL, MariaDB, and Aurora database engines, across all company-managed AWS accounts and environments (production, staging, development, and testing). This policy is binding for all employees, contractors, and third-party vendors who are involved in the architecture, deployment, administration, or access of these database resources. This includes Database Administrators, DevOps Engineers, Site Reliability Engineers, and Software Developers.

4.3 Policy Owner and Review

The Chief Information Security Officer (CISO) is the designated owner of this policy. The Data Governance Committee is responsible for its annual review and approval. The designated Compliance Officer, Jane Doe, is responsible for conducting quarterly audits to ensure adherence to the controls outlined herein. All revisions and updates to this policy will be documented and communicated to all relevant personnel.

4.4 Technical Controls and Mandatory Configurations

All RDS instances must be configured in strict accordance with the following technical controls. Failure to comply is a direct violation of company security policy.

4.4.1 Network Accessibility and Isolation

Public exposure of any database is strictly prohibited. It is mandatory that all RDS instances are provisioned with the 'PubliclyAccessible' parameter set to 'False'. No exceptions will be granted for this control. Databases must be deployed within designated private subnets of an approved Virtual Private Cloud (VPC). Network access must be restricted using Security Groups that adhere to the principle of least privilege. Security Group rules must only allow traffic from specific, authorized sources (e.g., application server security groups) on the designated database port.

4.4.2 Data Encryption

All data stored within RDS instances, their underlying storage, and their automated backups and manual snapshots must be encrypted at rest. This encryption must be enabled at the time of instance creation using AWS Key Management Service (KMS). Where possible, customer-managed keys (CMKs) are required. Furthermore, all connections to the database must

be encrypted in transit. Applications connecting to RDS must be configured to use and enforce a minimum of TLS version 1.2.

4.4.3 Backup and Recovery

Automated backups are mandatory for all production and staging RDS instances. The backup retention period must be configured for a minimum of thirty (30) days. This ensures sufficient capability for point-in-time recovery (PITR) to meet business continuity and disaster recovery objectives. The database recovery process must be tested on a semi-annual basis by the infrastructure team to validate the integrity of backups and the effectiveness of the recovery procedure. Results of these tests must be documented and submitted to the Compliance Officer.

4.4.4 Logging and Monitoring

Comprehensive logging must be enabled for all production database instances. The following logs must be activated and configured to export to Amazon CloudWatch Logs for centralized analysis and retention: audit, error, general, and slowquery logs. These logs must be retained within CloudWatch for a minimum period of 365 days to support security incident investigations and compliance audits.

4.4.5 Engine Version and Patching

All RDS instances must run on a stable, vendor-supported major version of the database engine (e.g., PostgreSQL 14.5 or higher). The "Auto minor version upgrade" feature must be enabled on all instances to ensure that the latest security patches released by AWS are applied in a timely manner during the defined maintenance window.

4.5 Policy Enforcement and Exceptions

Compliance with this policy will be continuously monitored through automated tools, including AWS Config and third-party security posture management platforms. Any identified deviation will generate a high-priority alert to the security team for immediate remediation. Non-compliance may result in disciplinary action. Any request for an exception to this policy must be submitted in writing to the CISO, detailing the business justification and proposed compensating controls. Exceptions will only be granted upon formal, written approval from both the CISO and the relevant department head. All approved exceptions will be documented and reviewed on a quarterly basis.

5.0 Network Security (VPC)

5.0 Network Security (VPC)

5.1 Purpose

The purpose of this policy is to establish the mandatory security controls and operational procedures required for the configuration, management, and monitoring of all Virtual Private Cloud (VPC) environments. This policy aims to enforce the principle of least privilege, ensure robust network segmentation, and maintain comprehensive visibility into all network traffic to protect company data assets from unauthorized access, modification, or exfiltration. Adherence to this policy is essential for maintaining the confidentiality, integrity, and availability of our cloud-based services and for satisfying our obligations under regulatory frameworks, including ISO 27001 and SOC 2.

5.2 Scope

This policy applies to all company cloud infrastructure deployed within any cloud service provider environment. It is mandatory for all personnel, including full-time employees, contractors, and third-party vendors, who are involved in the design, implementation, administration, or auditing of the company's cloud network architecture. This policy governs all VPCs, subnets, security groups, Network Access Control Lists (NACLs), internet gateways, NAT gateways, and associated network components across all production, development, and testing accounts.

5.3 Technical Controls

5.3.1 VPC Segmentation

All VPCs must be designed with a multi-tiered architecture that logically separates resources based on their function and sensitivity. A minimum of public and private subnets Must be implemented to isolate publicly accessible resources from internal application and data tiers. Direct internet access from private subnets is Strictly Prohibited; all outbound traffic from private subnets Must be routed through a NAT Gateway. Environments such as production, staging, and development Must be deployed in separate, isolated VPCs.

5.3.2 Security Group Configuration

Security Groups function as stateful firewalls for associated resources and Must be configured according to the principle of least privilege.

It is Mandatory that all default Security Groups within any VPC are configured to deny all inbound and outbound traffic by default. This default configuration, as defined in standard build template VPC-TPL-v3.4, Must not be modified.

Custom Security Groups must be created for specific applications or tiers. All rules within these groups Must be explicit, defining the specific protocol, port range, and source or destination IP address (or security group ID). The use of overly permissive source/destination ranges, such as 0.0.0.0/0, is Strictly Prohibited for any management ports (e.g., SSH, RDP) and should only be used for public-facing services (e.g., TCP/443) after a formal risk assessment.

5.3.3 Network Access Control Lists (NACLs)

NACLs provide a stateless, secondary layer of defense at the subnet level. While Security Groups are the primary control, NACLs Must be configured as a defense-in-depth measure. NACL rules should be configured to explicitly allow expected traffic and should complement, not replace, the granular rules defined in Security Groups.

5.3.4 Traffic Monitoring and Logging

Comprehensive network visibility is critical for incident detection and response. Therefore, VPC Flow Logs Must be enabled for all VPCs across all company cloud accounts and regions without exception. Logs Must be configured to capture both ACCEPTED and REJECTED traffic metadata. These logs must be exported to a centralized, secure logging account and retained for a minimum period of 365 days for audit and forensic purposes. The log format must conform to the standard defined in document CLD-LOG-FMT-v2.1 to ensure consistent parsing by security monitoring tools.

5.4 Roles and Responsibilities

The Cloud Engineering team is responsible for the implementation and maintenance of VPC configurations in accordance with this policy. The Security Operations Center (SOC) is responsible for the continuous monitoring of VPC Flow Logs and for investigating any anomalous activity. The designated Cloud Compliance Officer is responsible for conducting quarterly audits to verify that all VPCs and their associated components are compliant with the controls defined herein. Audit findings will be formally documented in the GRC platform, under audit series AUD-VPC-QTR.

5.5 Compliance and Enforcement

Compliance with this policy is mandatory. Automated configuration checks will be run daily to detect any deviations from the controls specified in this document. Any non-compliant configuration will generate a high-priority alert to the Cloud Engineering and Security teams for immediate remediation. Failure to adhere to this policy by any personnel may result in disciplinary action, up to and including termination of employment or contract, in accordance with the company's Human Resources policies.

5.6 Policy Review and Versioning

This policy document, version 5.0, revision 2.1, shall be reviewed on an annual basis or in response to significant changes in technology or the threat landscape. All amendments require formal approval from the Information Security Steering Committee.